IAM / CONTROL VALIDATION

Role-Based Access Control Test Report

Asterbridge Care Technologies Inc.

Active Directory and Windows NTFS clinic segregation test | Fictional organization, observed laboratory execution

RESULT PASS | 6 / 6 core functional tests achieved the expected outcome

DOCUMENT DETAIL	RECORDED VALUE
Working paper ID	LAB-IAM-001 / RBAC-WP-01
Portfolio exercise	IAM-T01 (limited NTFS subtest); not full application authorization
Execution date	12 October 2026, based on Windows VM screenshots
Environment	Asterbridge-WS01 (Windows 10 Pro), joined to mydomain.com
Identity source	Active Directory DS on Asterbridge-DC01; domain controller DC.mydomain.com
Systems reference	SYS-002: Active Directory DS; client-side lab NTFS folders
Report prepared by	GRC/IAM Lab Analyst (simulation); operator evidence supplied by lab owner
Evidence type	Real lab-generated screenshots; fictional identities and company

Executive result

Asterbridge configured separate Active Directory security groups for Kitchener and Hamilton front-desk staff and applied corresponding NTFS Modify permissions to two folders on a domain-joined Windows workstation. Hannah Reid (EMP-014) could create and read a file in the Kitchener folder but could not write to the Hamilton folder. Samuel Ortiz (EMP-017) demonstrated the reverse pattern and was also denied directory listing of the Kitchener folder.

All six primary read/write tests returned the expected outcome. Group membership and selected directory access checks provided additional corroboration. This is evidence that the tested local NTFS permissions operated as intended for these two accounts at the time of the lab. It is not evidence of access enforcement in Asterbridge Connect, actual clinics, production file shares, or the broader 140-person workforce.

1 Objective, scope and environment

Control objective: verify that a Kitchener front-desk identity can work within its assigned clinic folder and cannot write to the Hamilton clinic folder, and that a Hamilton front-desk identity has the reciprocal permissions. The control is based on least privilege and separation of access by clinic.

IN SCOPE	OUT OF SCOPE
Two AD-backed sample users: EMP-014 (hreid), EMP-017 (sortiz).	Clinical chart systems, appointment application, real patient records and SaaS tenant authorization.
Security groups GRP-CORP-AllStaff and clinic front-desk groups.	All other employee and contractor entitlements, delegated admins and cloud sign-ins.
C:\AsterbridgeLab\KIT-FrontDesk and \HAM-FrontDesk; local NTFS ACLs.	Network shares, production permissions, cross-device persistence and external partner access.

2 Configuration baseline

Eight sample domain accounts were observed enabled in Active Directory, and the GRP-CORP-AllStaff membership view showed eight employees. The focused RBAC assessment uses two of those employees. The workstation reported successful domain membership in mydomain.com, and the prior Hannah login test showed the expected domain identity and groups.

RESOURCE	EXPECTED CLINIC GROUP	NTFS ACCESS
KIT-FrontDesk	MYDOMAIN\GRP-CLINIC-KIT-FrontDesk	Modify (M)
HAM-FrontDesk	MYDOMAIN\GRP-CLINIC-HAM-FrontDesk	Modify (M)
Both folders	NT AUTHORITY\SYSTEM and BUILTIN\Administrators	Full Control (F)

Folder inheritance was removed on both test directories, and icacls reported successful processing with zero failures. The local parent folder and any unrelated access pathways were not separately audited. The test folder contents were synthetic text only.

3 Method and acceptance criteria

The analyst reviewed screenshots of the executed configuration and PowerShell commands. Tests compared specific actions against a predefined allow/deny expectation. A passed negative test means the action failed with an access-denied exception; a passed positive test means the file was created/read and the expected content appeared.

Testing was carried out with standard interactive user sessions; the available evidence does not constitute an assessment of every effective permission or administrator bypass route. Screenshots were supplied by the operator and were not independently re-run by the report author.

4 Test procedures and results

Test population: 2 of 8 enabled hybrid sample users, chosen deliberately to represent the two clinic Front Desk roles. This is a targeted functional test, not a statistical sample of Asterbridge's complete user population.

ID	PERSON / PROCEDURE	EXPECTED	OBSERVED	RESULT
TC-01	Hannah: write Hannah-Test.txt to KIT	Allowed	Set-Content succeeded	PASS
TC-02	Hannah: read Hannah-Test.txt in KIT	Allowed	Expected text returned	PASS
TC-03	Hannah: write Hannah-Test.txt to HAM	Denied	PermissionDenied error	PASS
TC-04	Samuel: write Samuel-Test.txt to HAM	Allowed	Set-Content succeeded	PASS
TC-05	Samuel: read Samuel-Test.txt in HAM	Allowed	Expected text returned	PASS
TC-06	Samuel: write Samuel-Test.txt to KIT	Denied	PermissionDenied error	PASS

Additional verification

CHECK	OBSERVED RESULT	SOURCE
Hannah domain sign-in + groups	mydomain\hreid; corporate and KIT FrontDesk groups present	E02
Hannah browses KIT folder	Hannah-Test text file visible in Explorer	E04; E05 companion visuals
Hannah opens HAM folder	Windows displayed a no-permission warning; operator did not grant access	E05
Samuel domain sign-in + groups	mydomain\sortiz; corporate and HAM FrontDesk groups present	E06–E07
Samuel lists KIT directory	Get-ChildItem returned UnauthorizedAccessException	E07

Result interpretation

No failed expectations were observed in the six scoped functional tests. These results support a narrow conclusion: the configured clinic-specific NTFS folder ACLs restricted these two standard user accounts on this workstation during the test. Successful group assignment is not, by itself, proof of application-layer authorization or ongoing governance.

5 Control and framework traceability

The following is a directional cross-reference for portfolio analysis, not a completed conformity assessment. Formal applicability, control design and operating effectiveness must be reviewed against the applicable original standards in later GRC projects.

REFERENCE	RELEVANCE TO THIS TEST	TESTED?
NIST CSF 2.0 – PR.AA-05	Access permissions and entitlements governed on a least-privilege basis.	Local NTFS allow/deny only
ISO/IEC 27001:2022 Annex A 5.15 / 5.18	Access control rules and access rights management.	Partial technical evidence
ISO/IEC 27001:2022 Annex A 8.3	Restriction of access to information and associated assets.	Local folder boundary
SOC 2 Security – CC6 logical access	Authorization design and enforcement are relevant to logical access criteria.	Illustrative; not SOC 2 testing
Asterbridge IAM-T01	Front Desk clinic separation included in the designed scenario.	Only workstation-folder proxy tested

Relationship to the master casebook

SYS-002 is the Active Directory DS system represented in this lab; SYS-005 is Asterbridge Connect, which was not deployed or tested here. The master casebook's IAM-01 is about Entra MFA, IAM-02 about employee/contractor offboarding and IAM-03 about privileged-access reviews. None of those controls is concluded effective by this folder test. The local RBAC working paper is filed under LAB-IAM-001 (AD configuration evidence), not LAB-IAM-003, which is reserved in the IAM blueprint for Entra MFA/Conditional Access.

6 Exceptions, limitations and improvement actions

TYPE	OBSERVATION / FOLLOW-UP
Exceptions	No deviation identified within the six core test expectations. This is not a population-wide clean opinion.
Coverage gap	The lab used local workstation folders, not central shares or clinic scheduling. Repeat with SYS-005 or a lab file server before claiming clinic application segmentation.
Governance gap	Manager approvals and system owner authorization were not evidenced in the supplied screenshots. Add simulated Jira request/approval records and owner attestation.
Auditability gap	Preserve original screenshots and command outputs with stable IDs, UTC timestamps if available, test operator and reviewer details.
Further technical tests	Check clinician, manager, generic staff and helpdesk identities; inheritance, alternate paths, explicit deny/access inheritance, and privileged account behavior.

Final working-paper conclusion

PASS WITH LIMITED SCOPE. The evidence supports the intended separation of tested front-desk folder access between EMP-014 and EMP-017 on Asterbridge-WS01 on 12 October 2026. No exception was observed in the six

targeted functional tests. The result cannot be extended to production systems, application permissions, all employees or independent audit assurance without additional evidence and testing.

7 Evidence register

All screenshots below were supplied during the hands-on lab. Cropped excerpts are reproduced in the appendix for readability; the original files retain their original names. The ID denotes this report's evidence index, not the master casebook's synthetic EVD-001 to EVD-022 series.

ID	ORIGINAL SCREENSHOT FILE	EVIDENCE / PRIMARY USE
E01	image(20261012-152411).png	Enabled account population (8 users).
E02	image(20261012-161513).png	Hannah identity and group membership.
E03	image(20261012-162642).png	NTFS permissions for both clinic folders.
E04	image(20261012-163130).png	Hannah's permitted/denied write and read commands.
E05	Screenshot 2026-10-12 124117.png	Hannah's Explorer access warning.
E06	image(20261012-164911).png	Samuel's permitted/denied write and read commands.
E07	image(20261012-165713).png	Samuel's memberships; denied Kitchener listing.

Chain of evidence

Evidence source: operator-provided VM captures in this project conversation. Images show a lab domain, example users and local folders. Some VM screenshots include local workstation times; no independently verified UTC clock, hashed originals or signed chain-of-custody record was provided. No credentials or patient data are included in these screenshots.

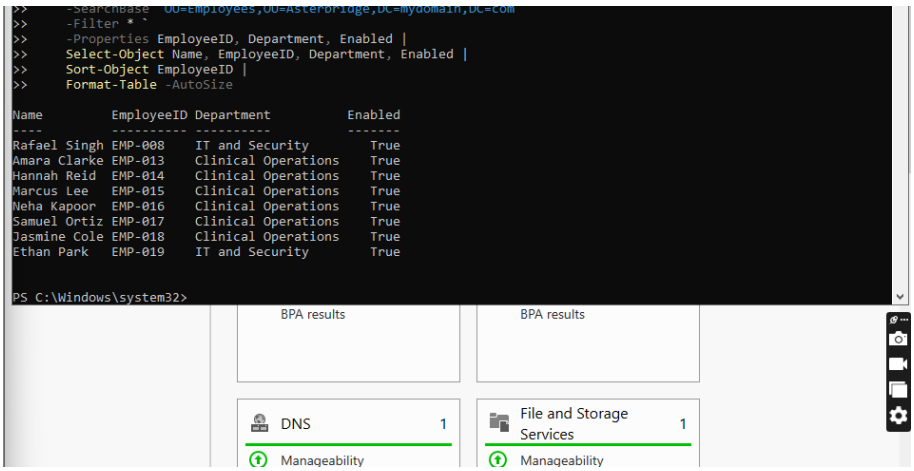
Reproduction checklist for later test cycles

- Snapshot or document the VM baseline, OS versions, hostname, AD domain and folder ACLs.
- Record approved test identities and expected group entitlements before testing.
- Capture terminal outputs for both successful and denied operations as standard users.
- Export machine-readable ACLs and group membership with dates and user identifiers.
- Attach access request, approver decision, independent reviewer and follow-up testing.
- Confirm that privileged or alternate access paths do not undermine the intended separation.

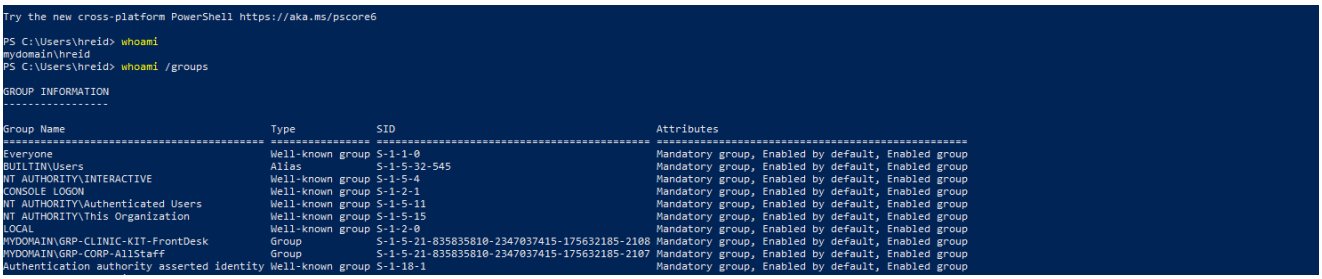
PREPARED FOR TRAINING AND PORTFOLIO USE

This report is an analyst-authored record of observed authorized lab behavior in a fictional company scenario. It is not a production security audit, legal compliance determination, or an assurance opinion issued by an independent auditor.

Appendix A | Identity and ACL evidence



E01 | Eight sample Active Directory accounts enabled.



E02 | Hannah Reid: domain identity and assigned groups.

Appendix B | ACLs and Hannah tests

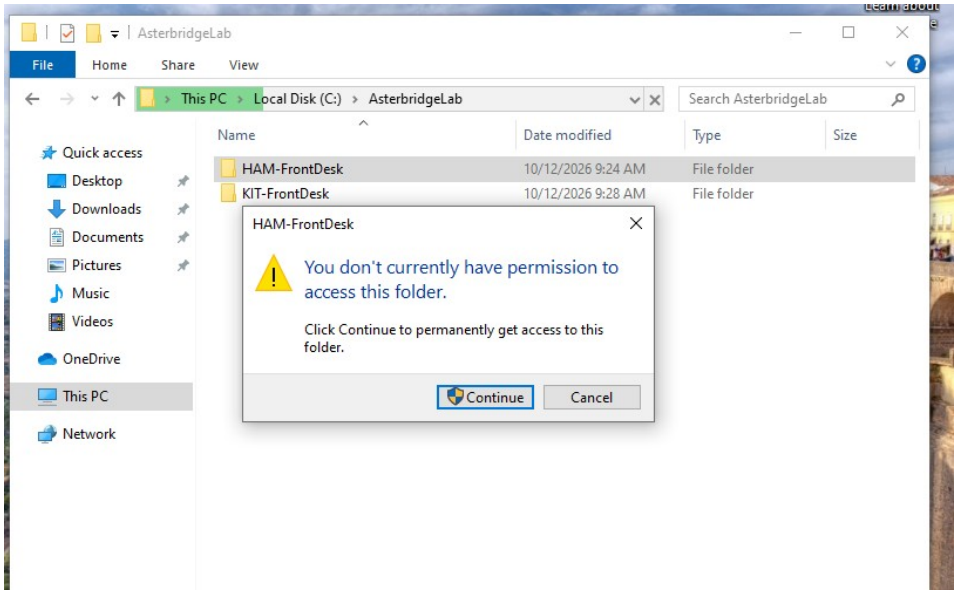


E03 | Kitchener and Hamilton folder ACLs from icacls.

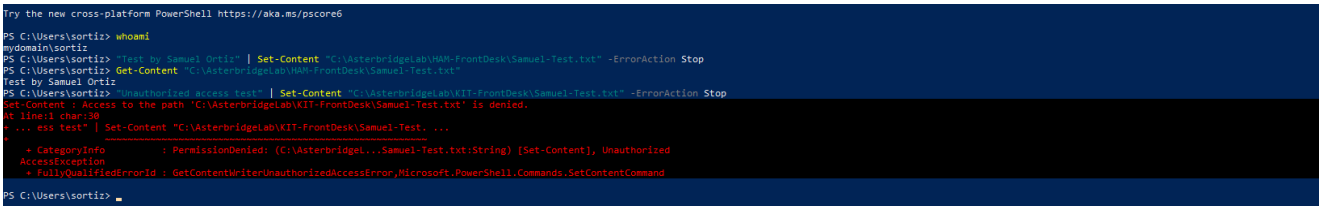


E04 | Hannah's allow/deny PowerShell results.

Appendix C | Folder access and Samuel tests

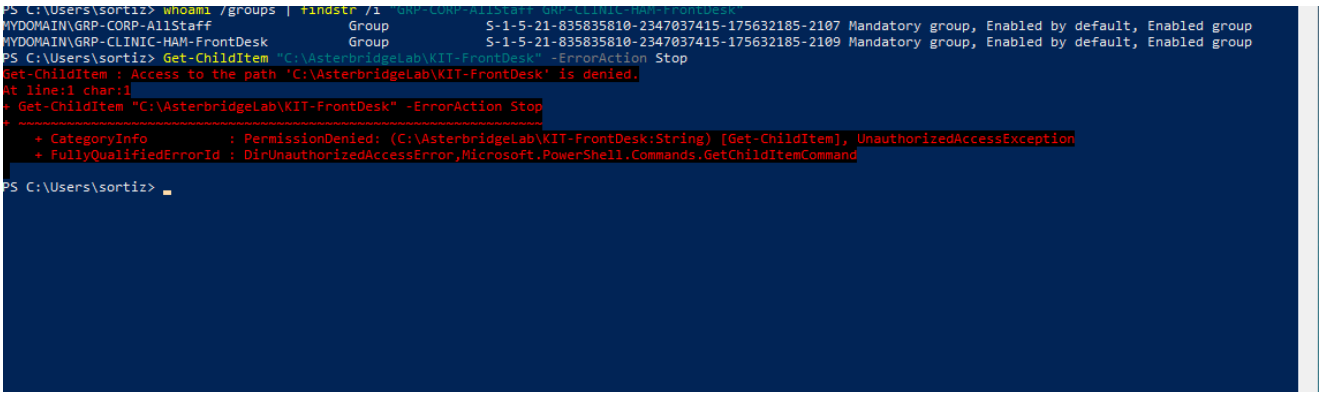


E05 | Hannah's Hamilton folder warning in File Explorer.



E06 | Samuel's allow/deny PowerShell results.

Appendix D | Final group and read-access check



E07 | Samuel's group memberships and denied Kitchener directory listing.

The source screenshot is cropped only to improve readability. The original image includes the entire PowerShell window. Screenshots E01–E07 are direct evidence of the steps performed; narrative assertions about approvals, recurring review or company-wide control effectiveness require additional artifacts.